

STRIDE Threat Model - Flipkart E-commerce Platform

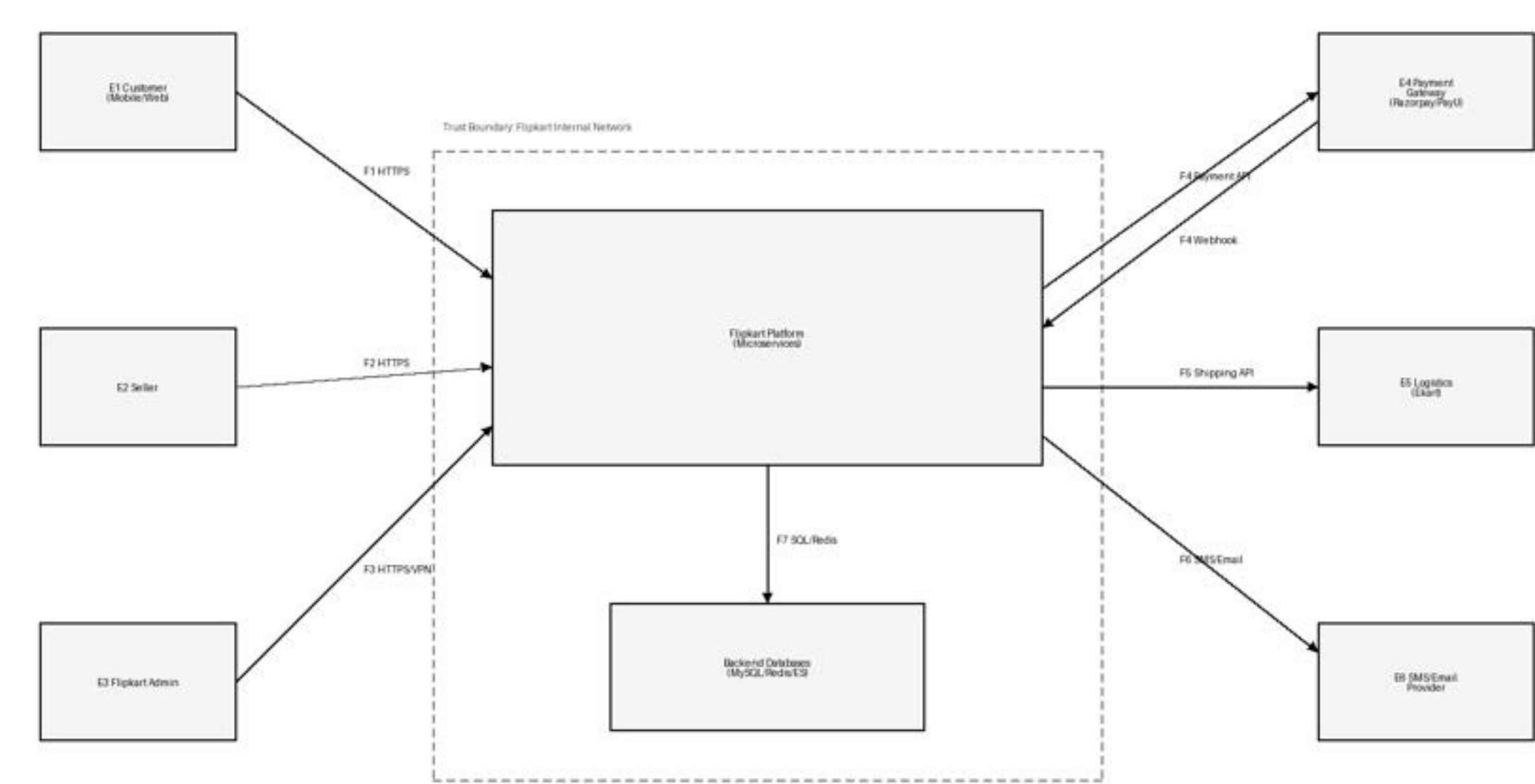
Assignment 1 - Secure Software Engineering

System Overview

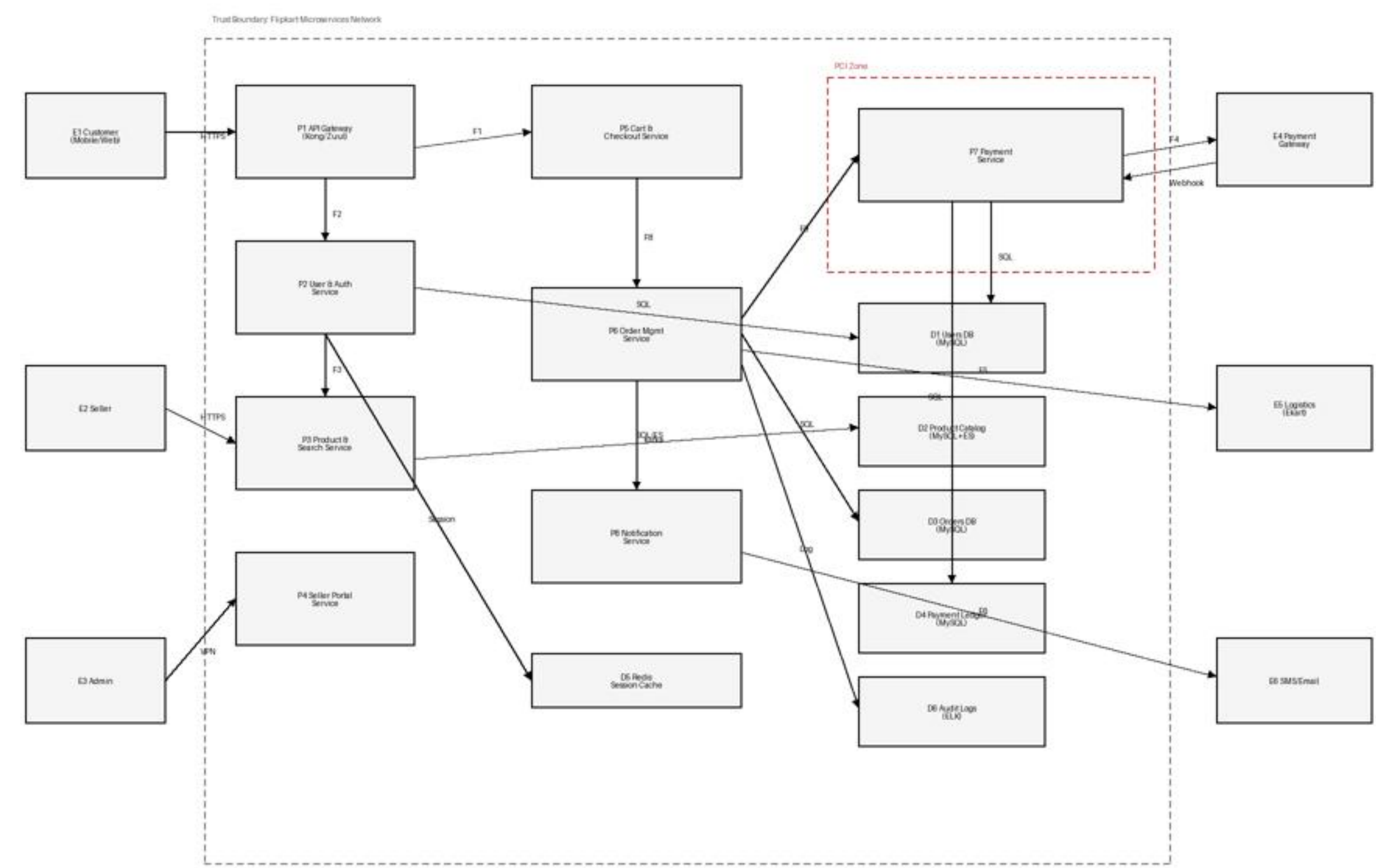
This threat model analyzes Flipkart, India's leading e-commerce marketplace serving 400M+ registered users and 500K+ sellers. The platform follows a microservices architecture deployed on Flipkart Cloud. Key components include: an API Gateway (Kong/Zuul) for request routing and rate limiting; a User & Auth Service supporting OTP-based mobile login and email/password authentication; a Product & Search Service backed by MySQL and Elasticsearch; a Cart & Checkout Service handling flash sales like Big Billion Days; an Order Management Service coordinating fulfillment with Ekart logistics; a Payment Service integrating Razorpay and PayU gateways within a PCI DSS compliant zone; a Seller Portal for marketplace operations; and a Notification Service for SMS, email, and push notifications.

In-scope: product browsing and search, user registration and OTP login, cart and checkout, order placement and tracking, seller onboarding and listing management, payment processing, and delivery coordination via Ekart. Out-of-scope: Flipkart Grocery (separate app), Myntra integration, advertising platform, and internal data analytics pipelines.

DFD Level 0 - Context Diagram



DFD Level 1 - Internal Microservices



STRIDE Mapping Summary

Spoofing: OTP brute-force on mobile login, credential stuffing, fake seller registration, payment webhook forgery, admin phishing, and mobile API key extraction. Tampering: price/coupon manipulation at checkout, SQL injection on search filters, stored XSS in reviews, cart bombing during flash sales, seller price manipulation, and API gateway request smuggling. Repudiation: delivery disputes without proof, refund fraud, and audit log tampering. Information Disclosure: mass PII exposure, payment card data leakage, and mobile app token extraction. Denial of Service: flash sale DDoS (Big Billion Days) and cart inventory hold abuse. Elevation of Privilege: IDOR on order/address endpoints enabling cross-user data access. Full details in STRIDE_Table.csv.

Likelihood and Impact Scale

Likelihood: Low (requires insider access or advanced skill), Medium (feasible with publicly available tools and moderate effort), High (easily automated or frequently observed in the wild). Impact: Low (limited to individual user inconvenience), Medium (financial loss or data exposure affecting a subset of users), High (platform-wide outage, mass data breach, regulatory penalties under IT Act 2000 or DPDP Act 2023).

Top 8 Prioritized Risks and Mitigations

1. OTP brute-force account takeover

Rationale: Flipkart's OTP login (4-6 digits) is vulnerable to automated guessing. Successful attack gives full account access including saved addresses, payment methods, and order history for 400M+ users.

Short-term: Rate-limit OTP attempts to 3 per phone/10 min, CAPTCHA on retry, 60-second OTP expiry.

Long-term: Adaptive risk-based authentication, device binding, and behavioral biometrics to detect automated attempts.

2. IDOR on order/address endpoints

Rationale: Sequential or predictable order IDs allow any authenticated user to access other users' orders, addresses, and phone numbers — a direct violation of DPDP Act 2023.

Short-term: Enforce object-level authorization on every endpoint; use UUIDs.

Long-term: Centralized authorization policy engine (OPA), automated IDOR scanning in CI/CD, and bug bounty program.

3. Price/coupon tampering at checkout

Rationale: Client-side price manipulation during checkout causes direct financial loss. During Big Billion Days with millions of transactions, even small per-order fraud scales massively.

Short-term: Server-side price recalculation from catalog DB, signed cart tokens.

Long-term: Order integrity microservice with real-time fraud scoring and automated anomaly alerting.

4. Razorpay/PayU webhook spoofing

Rationale: Forged payment success webhooks cause Flipkart to ship products without receiving payment. Direct revenue loss per incident.

Short-term: Verify HMAC signatures on all webhooks, validate amounts, and perform server-to-server payment status verification.

Long-term: Idempotent payment reconciliation service with automated discrepancy detection and alerting.

5. Flash sale DDoS (Big Billion Days)

Rationale: BBD generates 10x normal traffic. Attackers or scalper bots can amplify this to crash checkout, causing massive revenue loss and reputational damage.

Short-term: CDN-level DDoS protection, per-user rate limits, virtual waiting room queue for checkout.

Long-term: Bot detection ML model, auto-scaling microservices, and chaos engineering for flash sale resilience testing.

6. Mass user PII exposure

Rationale: 400M+ user records (phone, address, Aadhaar) make Flipkart a high-value target. Breach triggers DPDP Act penalties and catastrophic trust loss.

Short-term: Encrypt PII columns with AES-256, AWS KMS key management, and restrict DB access via IAM policies.

Long-term: Data classification and tokenization, DLP monitoring, and zero-trust database access architecture.

7. Fake seller registration and listing fraud

Rationale: Fraudulent sellers damage marketplace trust, cause financial losses to buyers, and expose Flipkart to regulatory action.

Short-term: Mandatory KYC with GST/PAN verification, escrow with 7-day payout hold for new sellers.

Long-term: ML-based seller fraud scoring, automated listing quality checks, and cross-platform fraud intelligence sharing.

8. Admin account compromise

Rationale: Admin access to seller payouts, catalog, and user data makes it a high-value target. Single compromised admin can cause platform-wide damage.

Short-term: FIDO2 hardware keys for admin auth, VPN-only admin access, and IP-bound sessions.

Long-term: Privileged access management (PAM), just-in-time access elevation, and continuous admin behavior monitoring.

Assumptions

1. Flipkart uses a microservices architecture with an API Gateway (Kong/Zuul) as the single entry point. 2. User authentication is primarily OTP-based mobile login with email/password as secondary. 3. Payment processing is handled by external gateways (Razorpay, PayU) with Flipkart's Payment Service in a PCI DSS compliant zone. 4. Ekart is the primary logistics partner with API-based integration. 5. Seller Portal is a separate service with its own authentication flow. 6. Data stores include MySQL for transactional data, Elasticsearch for product search, and Redis for session caching. 7. Inter-service communication uses gRPC and Kafka event streams.